

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 — Weighted Risk Scoring · Generated: 2026-06-25 · SHA: `61ed8c3` · Model: `risk = 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Risk Band Summary

Band	Count	Dependencies
CRITICAL	4	log4j-core, log4j-api, jackson-databind, typosquatted jackson-databind
HIGH	1	guava
MEDIUM	2	mysql-connector-java, commons-io
LOW	5	commons-lang3, jackson-core, jackson-annotations, junit-jupiter, guava-transitives

Ranked Remediation Backlog

#	Coordinate	Version	Band	Risk Score	Top CVE	CVSS	Fix Version
1	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	9.3	CVE-2019-16943	9.8	2.13.4.2
2	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	8.5	CVE-2021-44228	10.0	2.17.2
3	org.apache.logging.log4j:log4j-api	2.14.1	CRITICAL	8.5	CVE-2021-44228	10.0	2.17.2
4	com.fastxml.jackson.core:jackson-databind	2.9.8	CRITICAL	8.5	TYPOSQUATTED	—	REMOVE
5	com.google.guava:guava	24.1.1-jre	HIGH	6.9	CVE-2022-25647	7.7	30.0-jre
6	mysql:mysql-connector-java	8.0.30	MEDIUM	5.4	CVE-2023-21971	5.3	8.0.33
7	commons-io:commons-io	2.4	MEDIUM	4.9	CVE-2021-29425	4.8	2.7
8	org.apache.commons:commons-lang3	3.4	LOW	2.5	—	—	3.20.0
9	com.fasterxml.jackson.core:jackson-core	2.9.8	LOW	1.6	—	—	2.22.0
10	com.fasterxml.jackson.core:jackson-annotations	2.9.0	LOW	1.6	—	—	2.22.0
11	org.junit.jupiter:junit-jupiter	5.10.2	LOW	0.8	—	—	5.11.0

Component Score Detail (Top 7)

Dependency	CVE Severity	Exposure	Business Criticality	Risk Score	Band
jackson-databind:2.9.8	10.0	8.0	2.0	9.3	CRITICAL

log4j-core:2.14.1	10.0	7.0	4.0	8.5	CRITICAL
log4j-api:2.14.1	10.0	7.0	4.0	8.5	CRITICAL
[typosquatted] jackson-databind:2.9.8	0.0*	7.0	5.0	8.5	CRITICAL
guava:24.1.1-jre	8.7	7.0	2.0	6.9	HIGH
mysql-connector-java:8.0.30	5.3	7.0	3.0	5.4	MEDIUM
commons-io:2.4	4.8	7.0	2.0	4.9	MEDIUM

*Typosquatted artifact: CVE score 0 (unresolvable), supply-chain flag overrides band to CRITICAL and score to 8.5

Scoring model: CVE severity = max CVSS across all CVEs + 0.5 per additional CVE beyond first (capped at 10). Exposure = directness + scope + network-library bonus. Business criticality sourced from import-grep of `src/`. CRITICAL CVE floor: any dependency with a CRITICAL CVE is floor-banded to HIGH or above; dependencies with supply-chain flags are floor-banded to CRITICAL.

Scoring Rationale — Top 5

- 1. jackson-databind:2.9.8 (Risk 9.3 — CRITICAL)** Nine CVEs including four independent CRITICAL deserialization gadget-chain RCEs (CVSS 9.8 each). The density bonus saturates the CVE severity component to 10.0. As a direct compile dependency serving as a network/parsing library, exposure is 8.0. No direct import found in source (default criticality 2.0). Four CRITICAL CVEs floor the band to CRITICAL. Fix: upgrade to `2.13.4.2`.
- 2. log4j-core:2.14.1 (Risk 8.5 — CRITICAL)** Direct compile dependency imported in `DiscountCalculator.java`. CVE-2021-44228 (Log4Shell, CVSS 10.0) allows unauthenticated RCE via JNDI injection in any logged string — actively exploited in the wild since December 2021. CVE-2021-45046 (CVSS 9.0) bypasses the initial fix. Two CRITICAL CVEs floor the band. Business criticality raised to 4.0 because the logger is used directly in internal service logic. Fix: upgrade to `2.17.2`.
- 3. log4j-api:2.14.1 (Risk 8.5 — CRITICAL)** Paired with log4j-core, shares the same Log4Shell attack surface. Both CRITICAL CVEs apply. Must be upgraded in lockstep with log4j-core to `2.17.2`.
- 4. Typosquatted `com.fastxml.jackson.core:jackson-databind:2.9.8` (Risk 8.5 — CRITICAL)** Supply-chain attack artifact: groupid `com.fastxml` is missing "er" from the legitimate `com.fasterxml`. Unresolvable on Maven Central (confirmed). If a compromised mirror resolved this coordinate, arbitrary malicious bytecode would enter the compile classpath with no CVE detection possible. Business criticality set to 5.0 (supply-chain override). Action: remove this `<dependency>` block immediately.
- 5. guava:24.1.1-jre (Risk 6.9 — HIGH)** Direct compile dependency with 3 CVEs. CVE-2022-25647 (CVSS 7.7 HIGH) enables deserialization attack via Gson. Density bonus raises effective CVE severity to 8.7. No direct import in source. Fix: upgrade to `30.0.0-jre` (resolves CVE-2022-25647); `32.0.0-jre` resolves all three CVEs.

Priority Remediation Actions

Priority	Action	Effort	Impact
P0 — Immediate	Remove <code>com.fastxml.jackson.core:jackson-databind:2.9.8</code> (typosquat)	5 min	Supply-chain risk eliminated
P0 — Immediate	Remove <code>http://</code> untrusted repository from <code>pom.xml</code>	5 min	MITM risk eliminated
P0 — Immediate	Upgrade <code>log4j-core</code> + <code>log4j-api</code> → <code>2.17.2</code>	30 min	2 CRITICAL CVEs (Log4Shell) resolved
P1 — This sprint	Upgrade <code>jackson-databind</code> → <code>2.13.4.2</code>	1–2 h	9 CVEs including 4 CRITICAL RCEs resolved

P2 — Next sprint	Upgrade <code>guava</code> → <code>32.0.0-jre</code>	2–4 h (API review)	3 CVEs resolved
P2 — Next sprint	Upgrade <code>mysql-connector-java</code> → <code>8.0.33</code> + resolve GPL-2.0	2–4 h	CVE + license violation resolved
P3 — Hygiene	Upgrade <code>commons-io</code> → <code>2.22.0</code> , <code>commons-lang3</code> → <code>3.20.0</code>	30 min	Path traversal CVE + hygiene

Machine-readable source: `depscan-risk-report.json` · Generated by the *Dependency & Supply-Chain Plugin* — Stage 2 · Ready for Auto-Remediation (Stage 3) and PR Validation Agent (Stage 4)